



# ZAP Scanning Report

Site: <http://localhost:3000>

Generated on Thu, 6 Aug 2026 09:19:05

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

## Summary of Alerts

| Risk Level       | Number of Alerts |
|------------------|------------------|
| High             | 0                |
| Medium           | 4                |
| Low              | 9                |
| Informational    | 10               |
| False Positives: | 0                |

## Insights

| Level | Reason        | Site                                                      | Description                                                      | Statistic |
|-------|---------------|-----------------------------------------------------------|------------------------------------------------------------------|-----------|
| Low   | Warning       |                                                           | ZAP warnings logged - see the zap.log file for details           | 30        |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Percentage of responses with status code 1xx                     | 1 %       |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Percentage of responses with status code 2xx                     | 98 %      |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Percentage of responses with status code 4xx                     | 1 %       |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Percentage of endpoints with content type application/javascript | 64 %      |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Percentage of endpoints with content type application/json       | 21 %      |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Percentage of endpoints with content type font/woff2             | 1 %       |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Percentage of endpoints with content type image/svg+xml          | 2 %       |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Percentage of endpoints with content type text/css               | 2 %       |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Percentage of endpoints with content type text/html              | 4 %       |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Percentage of endpoints with content type text/plain             | 1 %       |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Percentage of endpoints with content type text/x-component       | 1 %       |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Percentage of endpoints with method GET                          | 96 %      |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Percentage of endpoints with method POST                         | 4 %       |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Count of total endpoints                                         | 75        |
| Info  | Informational | <a href="http://localhost:3000">http://localhost:3000</a> | Percentage of slow responses                                     | 23 %      |

# Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

## Alerts

| Name                                                                   | Risk Level    | Number of Instances |
|------------------------------------------------------------------------|---------------|---------------------|
| <a href="#">CSP: Wildcard Directive</a>                                | Medium        | 3                   |
| <a href="#">CSP: script-src unsafe-eval</a>                            | Medium        | 3                   |
| <a href="#">CSP: script-src unsafe-inline</a>                          | Medium        | 3                   |
| <a href="#">CSP: style-src unsafe-inline</a>                           | Medium        | 3                   |
| <a href="#">Cross-Origin-Embedder-Policy Header Missing or Invalid</a> | Low           | 1                   |
| <a href="#">Cross-Origin-Opener-Policy Header Missing or Invalid</a>   | Low           | 1                   |
| <a href="#">Cross-Origin-Resource-Policy Header Missing or Invalid</a> | Low           | Systemic            |
| <a href="#">Dangerous JS Functions</a>                                 | Low           | 1                   |
| <a href="#">Full Path Disclosure</a>                                   | Low           | 2                   |
| <a href="#">Permissions Policy Header Not Set</a>                      | Low           | Systemic            |
| <a href="#">Private IP Disclosure</a>                                  | Low           | 4                   |
| <a href="#">Timestamp Disclosure - Unix</a>                            | Low           | 2                   |
| <a href="#">X-Content-Type-Options Header Missing</a>                  | Low           | Systemic            |
| <a href="#">Base64 Disclosure</a>                                      | Informational | 11                  |
| <a href="#">Information Disclosure - Suspicious Comments</a>           | Informational | 31                  |
| <a href="#">Modern Web Application</a>                                 | Informational | 4                   |
| <a href="#">Non-Storable Content</a>                                   | Informational | Systemic            |
| <a href="#">Sec-Fetch-Dest Header is Missing</a>                       | Informational | 3                   |
| <a href="#">Sec-Fetch-Mode Header is Missing</a>                       | Informational | 3                   |
| <a href="#">Sec-Fetch-Site Header is Missing</a>                       | Informational | 3                   |
| <a href="#">Sec-Fetch-User Header is Missing</a>                       | Informational | 3                   |
| <a href="#">Session Management Response Identified</a>                 | Informational | 1                   |
| <a href="#">Storable but Non-Cacheable Content</a>                     | Informational | 2                   |

## Alert Detail

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Medium      | CSP: Wildcard Directive                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Description | Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. |
| URL         | <a href="http://localhost:3000">http://localhost:3000</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Node Name   | http://localhost:3000                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter  | content-security-policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence   | default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                                                                                                                    |
| Other Info | The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined:<br><br>connect-src                                                                                                                                                                                                                                                                                                                                                               |
| URL        | <a href="http://localhost:3000/robots.txt">http://localhost:3000/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Node Name  | http://localhost:3000/robots.txt                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter  | content-security-policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence   | default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                                                                                                                    |
| Other Info | The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined:<br><br>connect-src                                                                                                                                                                                                                                                                                                                                                               |
| URL        | <a href="http://localhost:3000/sitemap.xml">http://localhost:3000/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Node Name  | http://localhost:3000/sitemap.xml                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter  | content-security-policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence   | default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                                                                                                                    |
| Other Info | The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined:<br><br>connect-src                                                                                                                                                                                                                                                                                                                                                               |
| Instances  | 3                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Solution   | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.                                                                                                                                                                                                                                                                                                                                                                  |
| Reference  | <a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a><br><a href="https://caniuse.com/#search=content+security+policy">https://caniuse.com/#search=content+security+policy</a><br><a href="https://content-security-policy.com/">https://content-security-policy.com/</a><br><a href="https://github.com/HtmlUnit/htmlunit-csp">https://github.com/HtmlUnit/htmlunit-csp</a><br><a href="https://web.dev/articles/csp#resource-options">https://web.dev/articles/csp#resource-options</a> |
| CWE Id     | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| WASC Id    | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Plugin Id  | <a href="#">10055</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |

Medium

CSP: script-src unsafe-eval

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description | Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. |
| URL         | <a href="http://localhost:3000">http://localhost:3000</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Node Name   | http://localhost:3000                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter   | content-security-policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence    | default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                                                                                                                                                                                                                                               |
| Other Info  | script-src includes unsafe-eval.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| URL         | <a href="http://localhost:3000/robots.txt">http://localhost:3000/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Node Name   | http://localhost:3000/robots.txt                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter   | content-security-policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence    | default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                                                                                                                                                                                                                                               |
| Other Info  | script-src includes unsafe-eval.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| URL         | <a href="http://localhost:3000/sitemap.xml">http://localhost:3000/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Node Name   | http://localhost:3000/sitemap.xml                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter   | content-security-policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence    | default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                                                                                                                                                                                                                                               |
| Other Info  | script-src includes unsafe-eval.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Instances   | 3                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Solution    | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Reference   | <a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a><br><a href="https://caniuse.com/#search=content+security+policy">https://caniuse.com/#search=content+security+policy</a><br><a href="https://content-security-policy.com/">https://content-security-policy.com/</a><br><a href="https://github.com/HtmlUnit/htmlunit-csp">https://github.com/HtmlUnit/htmlunit-csp</a><br><a href="https://web.dev/articles/csp#resource-options">https://web.dev/articles/csp#resource-options</a>                                                                                                                            |
| CWE Id      | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| WASC Id     | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Plugin Id   | <a href="#">10055</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Medium      | CSP: script-src unsafe-inline                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Description | Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. |
| URL         | <a href="http://localhost:3000">http://localhost:3000</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Node Name   | http://localhost:3000                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter   | content-security-policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence    | default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                                                                                                                                                                                                                                               |
| Other Info  | script-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| URL         | <a href="http://localhost:3000/robots.txt">http://localhost:3000/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Node Name   | http://localhost:3000/robots.txt                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter   | content-security-policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence    | default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                                                                                                                                                                                                                                               |
| Other Info  | script-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| URL         | <a href="http://localhost:3000/sitemap.xml">http://localhost:3000/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Node Name   | http://localhost:3000/sitemap.xml                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter   | content-security-policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence    | default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob;; frame-src 'self' blob;; font-src 'self'; connect-src 'self' ws: wss;; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                                                                                                                                                                                                                                               |
| Other Info  | script-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Instances   | 3                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Solution    | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Reference   | <a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a><br><a href="https://caniuse.com/#search=content+security+policy">https://caniuse.com/#search=content+security+policy</a><br><a href="https://content-security-policy.com/">https://content-security-policy.com/</a><br><a href="https://github.com/HtmlUnit/htmlunit-csp">https://github.com/HtmlUnit/htmlunit-csp</a><br><a href="https://web.dev/articles/csp#resource-options">https://web.dev/articles/csp#resource-options</a>                                                                                                                            |

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CWE Id      | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| WASC Id     | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Plugin Id   | <a href="#">10055</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Medium      | CSP: style-src unsafe-inline                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Description | Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. |
| URL         | <a href="http://localhost:3000">http://localhost:3000</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Node Name   | http://localhost:3000                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter   | content-security-policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence    | default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; frame-src 'self' blob:; font-src 'self'; connect-src 'self' ws: wss:; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                                                                                                                                                                                                                                               |
| Other Info  | style-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| URL         | <a href="http://localhost:3000/robots.txt">http://localhost:3000/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Node Name   | http://localhost:3000/robots.txt                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter   | content-security-policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence    | default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; frame-src 'self' blob:; font-src 'self'; connect-src 'self' ws: wss:; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                                                                                                                                                                                                                                               |
| Other Info  | style-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| URL         | <a href="http://localhost:3000/sitemap.xml">http://localhost:3000/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Node Name   | http://localhost:3000/sitemap.xml                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter   | content-security-policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence    | default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob:; frame-src 'self' blob:; font-src 'self'; connect-src 'self' ws: wss:; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                                                                                                                                                                                                                                               |
| Other Info  | style-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Instances   | 3                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Solution    | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Reference   | <a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a><br><a href="https://caniuse.com/#search=content+security+policy">https://caniuse.com/#search=content+security+policy</a>                                                                                                                                                                                                                                                                                                                                                                                                                                       |

|           |                                                                                                                                                                                                                                                                                                         |
|-----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|           | <a href="https://content-security-policy.com/">https://content-security-policy.com/</a><br><a href="https://github.com/HtmlUnit/htmlunit-csp">https://github.com/HtmlUnit/htmlunit-csp</a><br><a href="https://web.dev/articles/csp#resource-options">https://web.dev/articles/csp#resource-options</a> |
| CWE Id    | <a href="#">693</a>                                                                                                                                                                                                                                                                                     |
| WASC Id   | 15                                                                                                                                                                                                                                                                                                      |
| Plugin Id | <a href="#">10055</a>                                                                                                                                                                                                                                                                                   |

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|-------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Low</b>  | <b>Cross-Origin-Embedder-Policy Header Missing or Invalid</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Description | Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).                                                                                                                                                                                                                                                                                                           |
| URL         | <a href="http://localhost:3000">http://localhost:3000</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Node Name   | http://localhost:3000                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Parameter   | Cross-Origin-Embedder-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Other Info  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Instances   | 1                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Solution    | <p>Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents.</p> <p>If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Embedder-Policy header (<a href="https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy">https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy</a>).</p> |
| Reference   | <a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy">https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy</a>                                                                                                                                                                                                                                                                                               |
| CWE Id      | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| WASC Id     | 14                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Plugin Id   | <a href="#">90004</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |

|             |                                                                                                                                                                                                                                        |
|-------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Low</b>  | <b>Cross-Origin-Opener-Policy Header Missing or Invalid</b>                                                                                                                                                                            |
| Description | Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak. |
| URL         | <a href="http://localhost:3000">http://localhost:3000</a>                                                                                                                                                                              |
| Node Name   | http://localhost:3000                                                                                                                                                                                                                  |
| Method      | GET                                                                                                                                                                                                                                    |
| Parameter   | Cross-Origin-Opener-Policy                                                                                                                                                                                                             |
| Attack      |                                                                                                                                                                                                                                        |
| Evidence    | same-origin-allow-popups                                                                                                                                                                                                               |
| Other Info  |                                                                                                                                                                                                                                        |
| Instances   | 1                                                                                                                                                                                                                                      |

|           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Solution  | <p>Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents.</p> <p>'same-origin-allow-popups' is considered as less secured and should be avoided.</p> <p>If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (<a href="https://caniuse.com/mdn-http_headers_cross-origin-opener-policy">https://caniuse.com/mdn-http_headers_cross-origin-opener-policy</a>).</p> |
| Reference | <a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy">https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy</a>                                                                                                                                                                                                                                                                                                                                                                               |
| CWE Id    | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| WASC Id   | 14                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Plugin Id | <a href="#">90004</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |

|             |                                                                                                                                                                                                                                         |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Low</b>  | <b>Cross-Origin-Resource-Policy Header Missing or Invalid</b>                                                                                                                                                                           |
| Description | Cross-Origin-Resource-Policy header is an opt-in header designed to counter side-channels attacks like Spectre. Resource should be specifically set as shareable amongst different origins.                                             |
| URL         | <a href="http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js">http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js</a> |
| Node Name   | http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._.js                                                                                                                                |
| Method      | GET                                                                                                                                                                                                                                     |
| Parameter   | Cross-Origin-Resource-Policy                                                                                                                                                                                                            |
| Attack      |                                                                                                                                                                                                                                         |
| Evidence    |                                                                                                                                                                                                                                         |
| Other Info  |                                                                                                                                                                                                                                         |
| URL         | <a href="http://localhost:3000/_next/static/chunks/_a0ff3932._.js">http://localhost:3000/_next/static/chunks/_a0ff3932._.js</a>                                                                                                         |
| Node Name   | http://localhost:3000/_next/static/chunks/_a0ff3932._.js                                                                                                                                                                                |
| Method      | GET                                                                                                                                                                                                                                     |
| Parameter   | Cross-Origin-Resource-Policy                                                                                                                                                                                                            |
| Attack      |                                                                                                                                                                                                                                         |
| Evidence    |                                                                                                                                                                                                                                         |
| Other Info  |                                                                                                                                                                                                                                         |
| URL         | <a href="http://localhost:3000/_next/static/chunks/_e084681a._.css">http://localhost:3000/_next/static/chunks/_e084681a._.css</a>                                                                                                       |
| Node Name   | http://localhost:3000/_next/static/chunks/_e084681a._.css                                                                                                                                                                               |
| Method      | GET                                                                                                                                                                                                                                     |
| Parameter   | Cross-Origin-Resource-Policy                                                                                                                                                                                                            |
| Attack      |                                                                                                                                                                                                                                         |
| Evidence    |                                                                                                                                                                                                                                         |
| Other Info  |                                                                                                                                                                                                                                         |
| URL         | <a href="http://localhost:3000/icon.svg">http://localhost:3000/icon.svg</a>                                                                                                                                                             |
| Node Name   | http://localhost:3000/icon.svg                                                                                                                                                                                                          |



|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Parameter  | Cross-Origin-Resource-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| URL        | <a href="http://localhost:3000/nycu-favicon.svg">http://localhost:3000/nycu-favicon.svg</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Node Name  | http://localhost:3000/nycu-favicon.svg                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Parameter  | Cross-Origin-Resource-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Solution   | <p>Ensure that the application/web server sets the Cross-Origin-Resource-Policy header appropriately, and that it sets the Cross-Origin-Resource-Policy header to 'same-origin' for all web pages.</p> <p>'same-site' is considered as less secured and should be avoided.</p> <p>If resources must be shared, set the header to 'cross-origin'.</p> <p>If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Resource-Policy header (<a href="https://caniuse.com/mdn-http_headers_cross-origin-resource-policy">https://caniuse.com/mdn-http_headers_cross-origin-resource-policy</a>).</p> |
| Reference  | <a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy">https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| CWE Id     | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| WASC Id    | 14                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Plugin Id  | <a href="#">90004</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |

|             |                                                                                                                                                     |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Low</b>  | <b>Dangerous JS Functions</b>                                                                                                                       |
| Description | A dangerous JS function seems to be in use that would leave the site vulnerable.                                                                    |
| URL         | <a href="http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js">http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js</a> |
| Node Name   | http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js                                                                                  |
| Method      | GET                                                                                                                                                 |
| Parameter   |                                                                                                                                                     |
| Attack      |                                                                                                                                                     |
| Evidence    | eval(                                                                                                                                               |
| Other Info  |                                                                                                                                                     |
| Instances   | 1                                                                                                                                                   |
| Solution    | See the references for security advice on the use of these functions.                                                                               |
| Reference   | <a href="https://v17.angular.io/guide/security">https://v17.angular.io/guide/security</a>                                                           |
| CWE Id      | <a href="#">749</a>                                                                                                                                 |

|           |                       |
|-----------|-----------------------|
| WASC Id   |                       |
| Plugin Id | <a href="#">10110</a> |

| Low         | Full Path Disclosure                                                                                                                    |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------|
| Description | The full path of files which might be sensitive has been exposed to the client.                                                         |
| URL         | <a href="http://localhost:3000/robots.txt">http://localhost:3000/robots.txt</a>                                                         |
| Node Name   | http://localhost:3000/robots.txt                                                                                                        |
| Method      | GET                                                                                                                                     |
| Parameter   |                                                                                                                                         |
| Attack      |                                                                                                                                         |
| Evidence    | /lib/                                                                                                                                   |
| Other Info  |                                                                                                                                         |
| URL         | <a href="http://localhost:3000/sitemap.xml">http://localhost:3000/sitemap.xml</a>                                                       |
| Node Name   | http://localhost:3000/sitemap.xml                                                                                                       |
| Method      | GET                                                                                                                                     |
| Parameter   |                                                                                                                                         |
| Attack      |                                                                                                                                         |
| Evidence    | /lib/                                                                                                                                   |
| Other Info  |                                                                                                                                         |
| Instances   | 2                                                                                                                                       |
| Solution    | Disable directory browsing in your web server. Refer to the web server documentation.                                                   |
| Reference   | <a href="https://owasp.org/www-community/attacks/Full_Path_Disclosure">https://owasp.org/www-community/attacks/Full_Path_Disclosure</a> |
| CWE Id      | <a href="#">209</a>                                                                                                                     |
| WASC Id     | 13                                                                                                                                      |
| Plugin Id   | <a href="#">110009</a>                                                                                                                  |

| Low         | Permissions Policy Header Not Set                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description | Permissions Policy Header is an added layer of security that helps to restrict from unauthorized access or usage of browser/client features by web resources. This policy ensures the user privacy by limiting or specifying the features of the browsers can be used by the web resources. Permissions Policy provides a set of standard HTTP headers that allow website owners to limit which features of browsers can be used by the page such as camera, microphone, location, full screen etc. |
| URL         | <a href="http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js">http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js</a>                                                                                                                                                                                                                                                             |
| Node Name   | http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._.js                                                                                                                                                                                                                                                                                                                                                                                            |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Parameter   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Other Info  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| URL        | <a href="http://localhost:3000/_next/static/chunks/_8bb8c147._.js">http://localhost:3000/_next/static/chunks/_8bb8c147._.js</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Node Name  | http://localhost:3000/_next/static/chunks/_8bb8c147._.js                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Parameter  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| URL        | <a href="http://localhost:3000/_next/static/chunks/_a0ff3932._.js">http://localhost:3000/_next/static/chunks/_a0ff3932._.js</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Node Name  | http://localhost:3000/_next/static/chunks/_a0ff3932._.js                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Parameter  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| URL        | <a href="http://localhost:3000/_next/static/chunks/app_layout_tsx_0a548d63._.js">http://localhost:3000/_next/static/chunks/app_layout_tsx_0a548d63._.js</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Node Name  | http://localhost:3000/_next/static/chunks/app_layout_tsx_0a548d63._.js                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Parameter  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_%40swc_helpers_cjs_b3dc30d6._.js">http://localhost:3000/_next/static/chunks/node_modules_%40swc_helpers_cjs_b3dc30d6._.js</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_@swc_helpers_cjs_b3dc30d6._.js                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Parameter  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Solution   | Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Reference  | <a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy">https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy</a><br><a href="https://developer.chrome.com/blog/feature-policy/">https://developer.chrome.com/blog/feature-policy/</a><br><a href="https://scotthelme.co.uk/a-new-security-header-feature-policy/">https://scotthelme.co.uk/a-new-security-header-feature-policy/</a><br><a href="https://w3c.github.io/webappsec-feature-policy/">https://w3c.github.io/webappsec-feature-policy/</a><br><a href="https://www.smashingmagazine.com/2018/12/feature-policy/">https://www.smashingmagazine.com/2018/12/feature-policy/</a> |
| CWE Id     | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| WASC Id    | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Plugin Id  | <a href="#">10063</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |

| Low         | Private IP Disclosure                                                                                                                                                                                                                              |
|-------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description | A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems. |
| URL         | <a href="http://localhost:3000">http://localhost:3000</a>                                                                                                                                                                                          |
| Node Name   | http://localhost:3000                                                                                                                                                                                                                              |
| Method      | GET                                                                                                                                                                                                                                                |
| Parameter   |                                                                                                                                                                                                                                                    |
| Attack      |                                                                                                                                                                                                                                                    |
| Evidence    | 172.30.0.1                                                                                                                                                                                                                                         |
| Other Info  | 172.30.0.1                                                                                                                                                                                                                                         |
| URL         | <a href="http://localhost:3000/">http://localhost:3000/</a>                                                                                                                                                                                        |
| Node Name   | http://localhost:3000/                                                                                                                                                                                                                             |
| Method      | GET                                                                                                                                                                                                                                                |
| Parameter   |                                                                                                                                                                                                                                                    |
| Attack      |                                                                                                                                                                                                                                                    |
| Evidence    | 172.30.0.1                                                                                                                                                                                                                                         |
| Other Info  | 172.30.0.1                                                                                                                                                                                                                                         |
| URL         | <a href="http://localhost:3000/robots.txt">http://localhost:3000/robots.txt</a>                                                                                                                                                                    |
| Node Name   | http://localhost:3000/robots.txt                                                                                                                                                                                                                   |
| Method      | GET                                                                                                                                                                                                                                                |
| Parameter   |                                                                                                                                                                                                                                                    |
| Attack      |                                                                                                                                                                                                                                                    |
| Evidence    | 172.30.0.1                                                                                                                                                                                                                                         |
| Other Info  | 172.30.0.1                                                                                                                                                                                                                                         |
| URL         | <a href="http://localhost:3000/sitemap.xml">http://localhost:3000/sitemap.xml</a>                                                                                                                                                                  |
| Node Name   | http://localhost:3000/sitemap.xml                                                                                                                                                                                                                  |
| Method      | GET                                                                                                                                                                                                                                                |
| Parameter   |                                                                                                                                                                                                                                                    |
| Attack      |                                                                                                                                                                                                                                                    |
| Evidence    | 172.30.0.1                                                                                                                                                                                                                                         |
| Other Info  | 172.30.0.1                                                                                                                                                                                                                                         |
| Instances   | 4                                                                                                                                                                                                                                                  |
| Solution    | Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP comment instead of HTML/JavaScript comment which can be seen by client browsers.                                                                          |
| Reference   | <a href="https://datatracker.ietf.org/doc/html/rfc1918">https://datatracker.ietf.org/doc/html/rfc1918</a>                                                                                                                                          |
| CWE Id      | <a href="#">497</a>                                                                                                                                                                                                                                |
| WASC Id     | 13                                                                                                                                                                                                                                                 |

|             |                                                                                                                                                                                       |
|-------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Plugin Id   | <a href="#">2</a>                                                                                                                                                                     |
| <b>Low</b>  | <b>Timestamp Disclosure - Unix</b>                                                                                                                                                    |
| Description | A timestamp was disclosed by the application/web server. - Unix                                                                                                                       |
| URL         | <a href="http://localhost:3000/_next/static/chunks/node_modules_84eac506._.js">http://localhost:3000/_next/static/chunks/node_modules_84eac506._.js</a>                               |
| Node Name   | http://localhost:3000/_next/static/chunks/node_modules_84eac506._.js                                                                                                                  |
| Method      | GET                                                                                                                                                                                   |
| Parameter   |                                                                                                                                                                                       |
| Attack      |                                                                                                                                                                                       |
| Evidence    | 1866099640                                                                                                                                                                            |
| Other Info  | 1866099640, which evaluates to: 2029-02-18 09:00:40.                                                                                                                                  |
| URL         | <a href="http://localhost:3000/_next/static/chunks/node_modules_%40floating-ui_1b6e7b6d._.js">http://localhost:3000/_next/static/chunks/node_modules_%40floating-ui_1b6e7b6d._.js</a> |
| Node Name   | http://localhost:3000/_next/static/chunks/node_modules_@floating-ui_1b6e7b6d._.js                                                                                                     |
| Method      | GET                                                                                                                                                                                   |
| Parameter   |                                                                                                                                                                                       |
| Attack      |                                                                                                                                                                                       |
| Evidence    | 1719601643                                                                                                                                                                            |
| Other Info  | 1719601643, which evaluates to: 2024-06-28 19:07:23.                                                                                                                                  |
| Instances   | 2                                                                                                                                                                                     |
| Solution    | Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.                                                   |
| Reference   | <a href="https://cwe.mitre.org/data/definitions/200.html">https://cwe.mitre.org/data/definitions/200.html</a>                                                                         |
| CWE Id      | <a href="#">497</a>                                                                                                                                                                   |
| WASC Id     | 13                                                                                                                                                                                    |
| Plugin Id   | <a href="#">10096</a>                                                                                                                                                                 |

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|-------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Low</b>  | <b>X-Content-Type-Options Header Missing</b>                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Description | The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing. |
| URL         | <a href="http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js">http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js</a>                                                                                                                                                                                                                              |
| Node Name   | http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._.js                                                                                                                                                                                                                                                                                                                                                             |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Parameter   | x-content-type-options                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Other Info  | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.                                                                                                                                                                                                                                |

|            |                                                                                                                                                                                                                                                                                                                                            |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|            | At "High" threshold this scan rule will not alert on client or server error responses.                                                                                                                                                                                                                                                     |
| URL        | <a href="http://localhost:3000/_next/static/chunks/_a0ff3932._.js">http://localhost:3000/_next/static/chunks/_a0ff3932._.js</a>                                                                                                                                                                                                            |
| Node Name  | http://localhost:3000/_next/static/chunks/_a0ff3932._.js                                                                                                                                                                                                                                                                                   |
| Method     | GET                                                                                                                                                                                                                                                                                                                                        |
| Parameter  | x-content-type-options                                                                                                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                                                                                                                            |
| Evidence   |                                                                                                                                                                                                                                                                                                                                            |
| Other Info | <p>This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.</p> <p>At "High" threshold this scan rule will not alert on client or server error responses.</p> |
| URL        | <a href="http://localhost:3000/_next/static/chunks/_e084681a._.css">http://localhost:3000/_next/static/chunks/_e084681a._.css</a>                                                                                                                                                                                                          |
| Node Name  | http://localhost:3000/_next/static/chunks/_e084681a._.css                                                                                                                                                                                                                                                                                  |
| Method     | GET                                                                                                                                                                                                                                                                                                                                        |
| Parameter  | x-content-type-options                                                                                                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                                                                                                                            |
| Evidence   |                                                                                                                                                                                                                                                                                                                                            |
| Other Info | <p>This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.</p> <p>At "High" threshold this scan rule will not alert on client or server error responses.</p> |
| URL        | <a href="http://localhost:3000/icon.svg">http://localhost:3000/icon.svg</a>                                                                                                                                                                                                                                                                |
| Node Name  | http://localhost:3000/icon.svg                                                                                                                                                                                                                                                                                                             |
| Method     | GET                                                                                                                                                                                                                                                                                                                                        |
| Parameter  | x-content-type-options                                                                                                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                                                                                                                            |
| Evidence   |                                                                                                                                                                                                                                                                                                                                            |
| Other Info | <p>This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.</p> <p>At "High" threshold this scan rule will not alert on client or server error responses.</p> |
| URL        | <a href="http://localhost:3000/nycu-favicon.svg">http://localhost:3000/nycu-favicon.svg</a>                                                                                                                                                                                                                                                |
| Node Name  | http://localhost:3000/nycu-favicon.svg                                                                                                                                                                                                                                                                                                     |
| Method     | GET                                                                                                                                                                                                                                                                                                                                        |
| Parameter  | x-content-type-options                                                                                                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                                                                                                                            |
| Evidence   |                                                                                                                                                                                                                                                                                                                                            |
| Other Info | <p>This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away</p>                                                                                                                               |



|            |                                                                                                                            |
|------------|----------------------------------------------------------------------------------------------------------------------------|
| URL        | <a href="#">http://localhost:3000/_next/static/chunks/components_ScholarshipWorkflowMermaid_tsx_16cfab4a._js</a>           |
| Node Name  | http://localhost:3000/_next/static/chunks/components_ScholarshipWorkflowMermaid_tsx_16cfab4a._js                           |
| Method     | GET                                                                                                                        |
| Parameter  |                                                                                                                            |
| Attack     |                                                                                                                            |
| Evidence   | components_ScholarshipWorkflowMermaid_tsx_16cfab4a                                                                         |
| Other Info | r???w?????SUB%j?!????G??ETHRS?f?w?l???zq?????                                                                              |
| URL        | <a href="#">http://localhost:3000/_next/static/chunks/components_common_ApplicationReviewDialog_tsx_18dbc797._js</a>       |
| Node Name  | http://localhost:3000/_next/static/chunks/components_common_ApplicationReviewDialog_tsx_18dbc797._js                       |
| Method     | GET                                                                                                                        |
| Parameter  |                                                                                                                            |
| Attack     |                                                                                                                            |
| Evidence   | _detailedApplication_student_data1                                                                                         |
| Other Info | ??)^t<br>i?SUB?*?nu????k                                                                                                   |
| URL        | <a href="#">http://localhost:3000/_next/static/chunks/components_student-wizard_bbbe0c5b._js</a>                           |
| Node Name  | http://localhost:3000/_next/static/chunks/components_student-wizard_bbbe0c5b._js                                           |
| Method     | GET                                                                                                                        |
| Parameter  |                                                                                                                            |
| Attack     |                                                                                                                            |
| Evidence   | export__default__as__Building2                                                                                             |
| Other Info | {SUB:h???u ??.ESC??DEL]J?                                                                                                  |
| URL        | <a href="#">http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a._js</a>                              |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a._js                                              |
| Method     | GET                                                                                                                        |
| Parameter  |                                                                                                                            |
| Attack     |                                                                                                                            |
| Evidence   | com/facebook/create-react-app/blob/7b1a32be6ec9f99a6c9a3c66813f3ac09c4736b9/packages/react-dev-utils/formatWebpackMessages |
| Other Info | r???}??n\$????j窗初槽?塿<br>oV?y?_?ss???w?i?=s?????sj????rPz????)l??+??VyZrC??O'z                                              |
| URL        | <a href="#">http://localhost:3000/_next/static/chunks/node_modules_next_dist_compiled_next-devtools_index_a9cb0712.js</a>  |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_next_dist_compiled_next-devtools_index_a9cb0712.js                  |
| Method     | GET                                                                                                                        |





|            |                                                                                                                                                                                                                                     |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js                                                                                                                                                                |
| Method     | GET                                                                                                                                                                                                                                 |
| Parameter  |                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                     |
| Evidence   | request that fired later will always be kept                                                                                                                                                                                        |
| Other Info | The following pattern was used: \bLATER\b and was detected in likely comment: "// the request that fired later will always be kept.", see evidence field for the suspicious comment/snippet.                                        |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js">http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js</a>                                                                             |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js                                                                                                                                                                |
| Method     | GET                                                                                                                                                                                                                                 |
| Parameter  |                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                     |
| Evidence   | // Display debug info in React DevTo                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bDEBUG\b and was detected in likely comment: "// Display debug info in React DevTools.", see evidence field for the suspicious comment/snippet.                                                    |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js">http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js</a>                                                                             |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js                                                                                                                                                                |
| Method     | GET                                                                                                                                                                                                                                 |
| Parameter  |                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                     |
| Evidence   | // FIXME:                                                                                                                                                                                                                           |
| Other Info | The following pattern was used: \bFIXME\b and was detected in likely comment: "// FIXME:", see evidence field for the suspicious comment/snippet.                                                                                   |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js">http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js</a>                                                                             |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js                                                                                                                                                                |
| Method     | GET                                                                                                                                                                                                                                 |
| Parameter  |                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                     |
| Evidence   | // TODO: Once we start trac                                                                                                                                                                                                         |
| Other Info | The following pattern was used: \bTODO\b and was detected 9 times, the first in likely comment: "// TODO: Once we start tracking back/forward history at each route level,", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js">http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js</a>                                                                             |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js                                                                                                                                                                |
| Method     | GET                                                                                                                                                                                                                                 |
| Parameter  |                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                     |
| Evidence   | // We only select the needed fields f                                                                                                                                                                                               |

|            |                                                                                                                                                                                                                                                                                    |
|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Other Info | The following pattern was used: \bSELECT\b and was detected 2 times, the first in likely comment: "// We only select the needed fields from the state.", see evidence field for the suspicious comment/snippet.                                                                    |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js">http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js</a>                                                                                                                            |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js                                                                                                                                                                                                               |
| Method     | GET                                                                                                                                                                                                                                                                                |
| Parameter  |                                                                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                                                                    |
| Evidence   | // from https://stackoverflowfl                                                                                                                                                                                                                                                    |
| Other Info | The following pattern was used: \bFROM\b and was detected 37 times, the first in likely comment: "// from https://stackoverflow.com/a/46181/1550155", see evidence field for the suspicious comment/snippet.                                                                       |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js">http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js</a>                                                                                                                            |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js                                                                                                                                                                                                               |
| Method     | GET                                                                                                                                                                                                                                                                                |
| Parameter  |                                                                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                                                                    |
| Evidence   | @1.0.12 there was a bug in the * infer                                                                                                                                                                                                                                             |
| Other Info | The following pattern was used: \bBUG\b and was detected 4 times, the first in likely comment: "/*<br>* Prior to zod@1.0.12 there was a bug in the<br>* inferred type of merged objects. Please<br>* upgrade if you are e", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js">http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js</a>                                                                                                                            |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js                                                                                                                                                                                                               |
| Method     | GET                                                                                                                                                                                                                                                                                |
| Parameter  |                                                                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                                                                    |
| Evidence   | ing ones set by the user, however,                                                                                                                                                                                                                                                 |
| Other Info | The following pattern was used: \bUSER\b and was detected 4 times, the first in likely comment: "// bodySerializer() needs all headers so we aren't dropping ones set by the user, however,", see evidence field for the suspicious comment/snippet.                               |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js">http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js</a>                                                                                                                            |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_0749d7b1._.js                                                                                                                                                                                                               |
| Method     | GET                                                                                                                                                                                                                                                                                |
| Parameter  |                                                                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                                                                    |
| Evidence   | m baseConfig Config where other config will b                                                                                                                                                                                                                                      |
| Other Info | The following pattern was used: \bWHERE\b and was detected 5 times, the first in likely comment: "/*                                                                                                                                                                               |

|            |                                                                                                                                                                                                                                                                                            |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|            | <p>* @param baseConfig Config where other config will be merged into. This object will be mutated.</p> <p>* @param configExtension P", see evidence field for the suspicious comment/snippet.</p>                                                                                          |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js</a>                                                                                                                  |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js                                                                                                                                                                                                              |
| Method     | GET                                                                                                                                                                                                                                                                                        |
| Parameter  |                                                                                                                                                                                                                                                                                            |
| Attack     |                                                                                                                                                                                                                                                                                            |
| Evidence   | find the pathname, query and hash and return                                                                                                                                                                                                                                               |
| Other Info | <p>The following pattern was used: \bQUERY\b and was detected in likely comment: "/*</p> <p>* Given a path this function will find the pathname, query and hash and return</p> <p>* them. This is useful to parse full paths ", see evidence field for the suspicious comment/snippet.</p> |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js</a>                                                                                                                  |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js                                                                                                                                                                                                              |
| Method     | GET                                                                                                                                                                                                                                                                                        |
| Parameter  |                                                                                                                                                                                                                                                                                            |
| Attack     |                                                                                                                                                                                                                                                                                            |
| Evidence   | // TODO: We should hoist th                                                                                                                                                                                                                                                                |
| Other Info | <p>The following pattern was used: \bTODO\b and was detected 10 times, the first in likely comment: "/* TODO: We should hoist the search params out of the FlightRouterState", see evidence field for the suspicious comment/snippet.</p>                                                  |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js</a>                                                                                                                  |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js                                                                                                                                                                                                              |
| Method     | GET                                                                                                                                                                                                                                                                                        |
| Parameter  |                                                                                                                                                                                                                                                                                            |
| Attack     |                                                                                                                                                                                                                                                                                            |
| Evidence   | // from user code generated by W                                                                                                                                                                                                                                                           |
| Other Info | <p>The following pattern was used: \bUSER\b and was detected 4 times, the first in likely comment: "/* from user code generated by Webpack. For more information see", see evidence field for the suspicious comment/snippet.</p>                                                          |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js</a>                                                                                                                  |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js                                                                                                                                                                                                              |
| Method     | GET                                                                                                                                                                                                                                                                                        |
| Parameter  |                                                                                                                                                                                                                                                                                            |
| Attack     |                                                                                                                                                                                                                                                                                            |
| Evidence   | // where rust does not have                                                                                                                                                                                                                                                                |
| Other Info | <p>The following pattern was used: \bWHERE\b and was detected 6 times, the first in likely comment: "/* where rust does not have easy way to represnt js's 53-bit float number type for the matching", see evidence field for the suspicious comment/snippet.</p>                          |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a_.js</a>                                                                                                                  |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                   |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a._.js                                                                                                                                                                                                                                                                                                                                    |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                               |
| Parameter  |                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Evidence   | ntime expose Object from vm, being that kind                                                                                                                                                                                                                                                                                                                                                                      |
| Other Info | <p>The following pattern was used: <code>\bFROM\b</code> and was detected 19 times, the first in likely comment: <code>"/**</code></p> <p><code>* this used to be previously:</code></p> <p><code>*</code></p> <p><code>* `return prototype === null    prototype === Object.prototype`</code></p> <p><code>*</code></p> <p><code>* but Edge ", see evidence field for the suspicious comment/snippet.</code></p> |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a._.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a._.js</a>                                                                                                                                                                                                                                       |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_next_dist_b0daae9a._.js                                                                                                                                                                                                                                                                                                                                    |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                               |
| Parameter  |                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Evidence   | to report this as a bug in Next.js.                                                                                                                                                                                                                                                                                                                                                                               |
| Other Info | The following pattern was used: <code>\bBUG\b</code> and was detected in likely comment: <code>"// user to report this as a bug in Next.js."</code> , see evidence field for the suspicious comment/snippet.                                                                                                                                                                                                      |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js</a>                                                                                                                                                                                                                         |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js                                                                                                                                                                                                                                                                                                                             |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                               |
| Parameter  |                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Evidence   | if that's what the user passed in, hence th                                                                                                                                                                                                                                                                                                                                                                       |
| Other Info | <p>The following pattern was used: <code>\bUSER\b</code> and was detected 3 times, the first in likely comment: <code>"/**</code></p> <p><code>* Note that we intentionally do not use `url.searchParams.set` here:</code></p> <p><code>*</code></p> <p><code>* const url = new URL('https://example.com/s', see evidence field for the suspicious comment/snippet.</code></p>                                    |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js</a>                                                                                                                                                                                                                         |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js                                                                                                                                                                                                                                                                                                                             |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                               |
| Parameter  |                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                   |

|            |                                                                                                                                                                                                                                    |
|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidence   | // (where these errors can oc                                                                                                                                                                                                      |
| Other Info | The following pattern was used: \bWHERE\b and was detected 14 times, the first in likely comment: "// (where these errors can occur), we will get the correct pathname.", see evidence field for the suspicious comment/snippet.   |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js</a>                                          |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js                                                                                                                                              |
| Method     | GET                                                                                                                                                                                                                                |
| Parameter  |                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                    |
| Evidence   | // TODO: Dispatch error eve                                                                                                                                                                                                        |
| Other Info | The following pattern was used: \bTODO\b and was detected 62 times, the first in likely comment: "// TODO: Dispatch error event", see evidence field for the suspicious comment/snippet.                                           |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js</a>                                          |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js                                                                                                                                              |
| Method     | GET                                                                                                                                                                                                                                |
| Parameter  |                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                    |
| Evidence   | // `__nextppronly` query is present. This is                                                                                                                                                                                       |
| Other Info | The following pattern was used: \bQUERY\b and was detected 5 times, the first in likely comment: "// `__nextppronly` query is present. This is only enabled when the", see evidence field for the suspicious comment/snippet.      |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js</a>                                          |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js                                                                                                                                              |
| Method     | GET                                                                                                                                                                                                                                |
| Parameter  |                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                    |
| Evidence   | gURL=set-attributes-from-props.js.map                                                                                                                                                                                              |
| Other Info | The following pattern was used: \bFROM\b and was detected 76 times, the first in likely comment: "///# sourceMappingURL=set-attributes-from-props.js.map", see evidence field for the suspicious comment/snippet.                  |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js</a>                                          |
| Node Name  | http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js                                                                                                                                              |
| Method     | GET                                                                                                                                                                                                                                |
| Parameter  |                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                    |
| Evidence   | it didn't, due to a bug or race condition,                                                                                                                                                                                         |
| Other Info | The following pattern was used: \bBUG\b and was detected 2 times, the first in likely comment: "// If for some reasons it didn't, due to a bug or race condition, then on", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js</a>                                          |

|            |                                                                                                                                                                                                                                                                   |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Node Name  | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_client_cf1d9188._.js</a>                                                                         |
| Method     | GET                                                                                                                                                                                                                                                               |
| Parameter  |                                                                                                                                                                                                                                                                   |
| Attack     |                                                                                                                                                                                                                                                                   |
| Evidence   | ra prefetch request later, since we already h                                                                                                                                                                                                                     |
| Other Info | The following pattern was used: \bLATER\b and was detected 3 times, the first in likely comment: "// prefetch cache so that we can skip an extra prefetch request later, since we already have the data.", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_compiled_5150ccfd._.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_compiled_5150ccfd._.js</a>                                                                     |
| Node Name  | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_compiled_5150ccfd._.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_compiled_5150ccfd._.js</a>                                                                     |
| Method     | GET                                                                                                                                                                                                                                                               |
| Parameter  |                                                                                                                                                                                                                                                                   |
| Attack     |                                                                                                                                                                                                                                                                   |
| Evidence   | // TODO: rename these field                                                                                                                                                                                                                                       |
| Other Info | The following pattern was used: \bTODO\b and was detected 3 times, the first in likely comment: "// TODO: rename these fields to something more meaningful.", see evidence field for the suspicious comment/snippet.                                              |
| URL        | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_compiled_5150ccfd._.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_compiled_5150ccfd._.js</a>                                                                     |
| Node Name  | <a href="http://localhost:3000/_next/static/chunks/node_modules_next_dist_compiled_5150ccfd._.js">http://localhost:3000/_next/static/chunks/node_modules_next_dist_compiled_5150ccfd._.js</a>                                                                     |
| Method     | GET                                                                                                                                                                                                                                                               |
| Parameter  |                                                                                                                                                                                                                                                                   |
| Attack     |                                                                                                                                                                                                                                                                   |
| Evidence   | ogic is copy-pasted from similar logic in th                                                                                                                                                                                                                      |
| Other Info | The following pattern was used: \bFROM\b and was detected 4 times, the first in likely comment: "// This logic is copy-pasted from similar logic in the DevTools backend.", see evidence field for the suspicious comment/snippet.                                |
| URL        | <a href="http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js">http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js</a>                                                                                                               |
| Node Name  | <a href="http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js">http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js</a>                                                                                                               |
| Method     | GET                                                                                                                                                                                                                                                               |
| Parameter  |                                                                                                                                                                                                                                                                   |
| Attack     |                                                                                                                                                                                                                                                                   |
| Evidence   | a Refresh Boundary later.                                                                                                                                                                                                                                         |
| Other Info | The following pattern was used: \bLATER\b and was detected in likely comment: "// still a Refresh Boundary later.", see evidence field for the suspicious comment/snippet.                                                                                        |
| URL        | <a href="http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js">http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js</a>                                                                                                               |
| Node Name  | <a href="http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js">http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js</a>                                                                                                               |
| Method     | GET                                                                                                                                                                                                                                                               |
| Parameter  |                                                                                                                                                                                                                                                                   |
| Attack     |                                                                                                                                                                                                                                                                   |

|            |                                                                                                                                                                                                                                                                             |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidence   | // TODO(luke.sandberg): we                                                                                                                                                                                                                                                  |
| Other Info | The following pattern was used: \bTODO\b and was detected 12 times, the first in likely comment: "// TODO(luke.sandberg): we could support raw values here, but would need a discriminator beyond 'not a function'", see evidence field for the suspicious comment/snippet. |
| URL        | <a href="http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js">http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js</a>                                                                                                                         |
| Node Name  | http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js                                                                                                                                                                                                          |
| Method     | GET                                                                                                                                                                                                                                                                         |
| Parameter  |                                                                                                                                                                                                                                                                             |
| Attack     |                                                                                                                                                                                                                                                                             |
| Evidence   | ative to the origin where a chunk can be fetc                                                                                                                                                                                                                               |
| Other Info | The following pattern was used: \bWHERE\b and was detected 2 times, the first in likely comment: "/*<br>* Returns the URL relative to the origin where a chunk can be fetched from.<br>*/", see evidence field for the suspicious comment/snippet.                          |
| URL        | <a href="http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js">http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js</a>                                                                                                                         |
| Node Name  | http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js                                                                                                                                                                                                          |
| Method     | GET                                                                                                                                                                                                                                                                         |
| Parameter  |                                                                                                                                                                                                                                                                             |
| Attack     |                                                                                                                                                                                                                                                                             |
| Evidence   | consistent from the user's perspective.                                                                                                                                                                                                                                     |
| Other Info | The following pattern was used: \bUSER\b and was detected in likely comment: "// the HTML somewhat consistent from the user's perspective.", see evidence field for the suspicious comment/snippet.                                                                         |
| URL        | <a href="http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js">http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js</a>                                                                                                                         |
| Node Name  | http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js                                                                                                                                                                                                          |
| Method     | GET                                                                                                                                                                                                                                                                         |
| Parameter  |                                                                                                                                                                                                                                                                             |
| Attack     |                                                                                                                                                                                                                                                                             |
| Evidence   | ead of accessing it from the module object t                                                                                                                                                                                                                                |
| Other Info | The following pattern was used: \bFROM\b and was detected 20 times, the first in likely comment: "// We need to store this here instead of accessing it from the module object to:", see evidence field for the suspicious comment/snippet.                                 |
| URL        | <a href="http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js">http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js</a>                                                                                                                         |
| Node Name  | http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js                                                                                                                                                                                                          |
| Method     | GET                                                                                                                                                                                                                                                                         |
| Parameter  |                                                                                                                                                                                                                                                                             |
| Attack     |                                                                                                                                                                                                                                                                             |
| Evidence   | onally followed by ?query or #fragment. */                                                                                                                                                                                                                                  |
| Other Info | The following pattern was used: \bQUERY\b and was detected 3 times, the first in likely comment: "/*                                                                                                                                                                        |



|            |                                                                                                                                                                                                                                      |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|            | <p>* Checks if a given path/URL ends with .js, optionally followed by ?query or #fragment.</p> <p>*/", see evidence field for the suspicious comment/snippet.</p>                                                                    |
| URL        | <a href="http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js">http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js</a>                                                                                  |
| Node Name  | http://localhost:3000/_next/static/chunks/turbopack-_cdba956c._.js                                                                                                                                                                   |
| Method     | GET                                                                                                                                                                                                                                  |
| Parameter  |                                                                                                                                                                                                                                      |
| Attack     |                                                                                                                                                                                                                                      |
| Evidence   | stylesheet: https://bugs.webkit.org/show_bug                                                                                                                                                                                         |
| Other Info | The following pattern was used: \bBUGS\b and was detected in likely comment: "// pointing to the same URL as the stylesheet: https://bugs.webkit.org/show_bug.cgi?id=187726", see evidence field for the suspicious comment/snippet. |
| Instances  | 31                                                                                                                                                                                                                                   |
| Solution   | Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.                                                                                                                 |
| Reference  |                                                                                                                                                                                                                                      |
| CWE Id     | <a href="#">615</a>                                                                                                                                                                                                                  |
| WASC Id    | 13                                                                                                                                                                                                                                   |
| Plugin Id  | <a href="#">10027</a>                                                                                                                                                                                                                |

| Informational | Modern Web Application                                                                                                                                                   |
|---------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one. |
| URL           | <a href="http://localhost:3000">http://localhost:3000</a>                                                                                                                |
| Node Name     | http://localhost:3000                                                                                                                                                    |
| Method        | GET                                                                                                                                                                      |
| Parameter     |                                                                                                                                                                          |
| Attack        |                                                                                                                                                                          |
| Evidence      | <script src="/_next/static/chunks/node_modules_next_dist_compiled_react-dom_1e674e59._.js" async=""></script>                                                            |
| Other Info    | No links have been found while there are scripts, which is an indication that this is a modern web application.                                                          |
| URL           | <a href="http://localhost:3000/">http://localhost:3000/</a>                                                                                                              |
| Node Name     | http://localhost:3000/                                                                                                                                                   |
| Method        | GET                                                                                                                                                                      |
| Parameter     |                                                                                                                                                                          |
| Attack        |                                                                                                                                                                          |
| Evidence      | <script src="/_next/static/chunks/node_modules_next_dist_compiled_react-dom_1e674e59._.js" async=""></script>                                                            |
| Other Info    | No links have been found while there are scripts, which is an indication that this is a modern web application.                                                          |
| URL           | <a href="http://localhost:3000/robots.txt">http://localhost:3000/robots.txt</a>                                                                                          |

|            |                                                                                                                 |
|------------|-----------------------------------------------------------------------------------------------------------------|
| Node Name  | http://localhost:3000/robots.txt                                                                                |
| Method     | GET                                                                                                             |
| Parameter  |                                                                                                                 |
| Attack     |                                                                                                                 |
| Evidence   | <script src="/_next/static/chunks/node_modules_next_dist_compiled_react-dom_1e674e59._.js" async=""></script>   |
| Other Info | No links have been found while there are scripts, which is an indication that this is a modern web application. |
| URL        | <a href="http://localhost:3000/sitemap.xml">http://localhost:3000/sitemap.xml</a>                               |
| Node Name  | http://localhost:3000/sitemap.xml                                                                               |
| Method     | GET                                                                                                             |
| Parameter  |                                                                                                                 |
| Attack     |                                                                                                                 |
| Evidence   | <script src="/_next/static/chunks/node_modules_next_dist_compiled_react-dom_1e674e59._.js" async=""></script>   |
| Other Info | No links have been found while there are scripts, which is an indication that this is a modern web application. |
| Instances  | 4                                                                                                               |
| Solution   | This is an informational alert and so no changes are required.                                                  |
| Reference  |                                                                                                                 |
| CWE Id     |                                                                                                                 |
| WASC Id    |                                                                                                                 |
| Plugin Id  | <a href="#">10109</a>                                                                                           |

| Informational | Non-Storable Content                                                                                                                                                                                                                        |
|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | The response contents are not storable by caching components such as proxy servers. If the response does not contain sensitive, personal or user-specific information, it may benefit from being stored and cached, to improve performance. |
| URL           | <a href="http://localhost:3000">http://localhost:3000</a>                                                                                                                                                                                   |
| Node Name     | http://localhost:3000                                                                                                                                                                                                                       |
| Method        | GET                                                                                                                                                                                                                                         |
| Parameter     |                                                                                                                                                                                                                                             |
| Attack        |                                                                                                                                                                                                                                             |
| Evidence      | no-store                                                                                                                                                                                                                                    |
| Other Info    |                                                                                                                                                                                                                                             |
| URL           | <a href="http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js">http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js</a>     |
| Node Name     | http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._.js                                                                                                                                    |
| Method        | GET                                                                                                                                                                                                                                         |
| Parameter     |                                                                                                                                                                                                                                             |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence   | no-store                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| URL        | <a href="http://localhost:3000/_next/static/chunks/_e084681a._.css">http://localhost:3000/_next/static/chunks/_e084681a._.css</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Node Name  | http://localhost:3000/_next/static/chunks/_e084681a._.css                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence   | no-store                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| URL        | <a href="http://localhost:3000/robots.txt">http://localhost:3000/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Node Name  | http://localhost:3000/robots.txt                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence   | no-store                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| URL        | <a href="http://localhost:3000/sitemap.xml">http://localhost:3000/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Node Name  | http://localhost:3000/sitemap.xml                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence   | no-store                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Instances  | Systemic                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Solution   | <p>The content may be marked as storable by ensuring that the following conditions are satisfied:</p> <p>The request method must be understood by the cache and defined as being cacheable ("GET", "HEAD", and "POST" are currently defined as cacheable)</p> <p>The response status code must be understood by the cache (one of the 1XX, 2XX, 3XX, 4XX, or 5XX response classes are generally understood)</p> <p>The "no-store" cache directive must not appear in the request or response header fields</p> <p>For caching by "shared" caches such as "proxy" caches, the "private" response directive must not appear in the response</p> <p>For caching by "shared" caches such as "proxy" caches, the "Authorization" header field must not appear in the request, unless the response explicitly allows it (using one of the "must-revalidate", "public", or "s-maxage" Cache-Control response directives)</p> <p>In addition to the conditions above, at least one of the following conditions must also be satisfied by the response:</p> |

|           |                                                                                                                                                                                                                                                                                                                                                                                                                             |
|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|           | <p>It must contain an "Expires" header field</p> <p>It must contain a "max-age" response directive</p> <p>For "shared" caches such as "proxy" caches, it must contain a "s-maxage" response directive</p> <p>It must contain a "Cache Control Extension" that allows it to be cached</p> <p>It must have a status code that is defined as cacheable by default (200, 203, 204, 206, 300, 301, 404, 405, 410, 414, 501).</p> |
| Reference | <a href="https://datatracker.ietf.org/doc/html/rfc7234">https://datatracker.ietf.org/doc/html/rfc7234</a><br><a href="https://datatracker.ietf.org/doc/html/rfc7231">https://datatracker.ietf.org/doc/html/rfc7231</a><br><a href="https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html">https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html</a>                                                                     |
| CWE Id    | <a href="#">524</a>                                                                                                                                                                                                                                                                                                                                                                                                         |
| WASC Id   | 13                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Plugin Id | <a href="#">10049</a>                                                                                                                                                                                                                                                                                                                                                                                                       |

| Informational | Sec-Fetch-Dest Header is Missing                                                                                                                                                                                                        |
|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | Specifies how and where the data would be used. For instance, if the value is audio, then the requested resource must be audio data and not any other type of resource.                                                                 |
| URL           | <a href="http://localhost:3000">http://localhost:3000</a>                                                                                                                                                                               |
| Node Name     | http://localhost:3000                                                                                                                                                                                                                   |
| Method        | GET                                                                                                                                                                                                                                     |
| Parameter     | Sec-Fetch-Dest                                                                                                                                                                                                                          |
| Attack        |                                                                                                                                                                                                                                         |
| Evidence      |                                                                                                                                                                                                                                         |
| Other Info    |                                                                                                                                                                                                                                         |
| URL           | <a href="http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js">http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js</a> |
| Node Name     | http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._.js                                                                                                                                |
| Method        | GET                                                                                                                                                                                                                                     |
| Parameter     | Sec-Fetch-Dest                                                                                                                                                                                                                          |
| Attack        |                                                                                                                                                                                                                                         |
| Evidence      |                                                                                                                                                                                                                                         |
| Other Info    |                                                                                                                                                                                                                                         |
| URL           | <a href="http://localhost:3000/icon.svg">http://localhost:3000/icon.svg</a>                                                                                                                                                             |
| Node Name     | http://localhost:3000/icon.svg                                                                                                                                                                                                          |
| Method        | GET                                                                                                                                                                                                                                     |
| Parameter     | Sec-Fetch-Dest                                                                                                                                                                                                                          |
| Attack        |                                                                                                                                                                                                                                         |
| Evidence      |                                                                                                                                                                                                                                         |
| Other Info    |                                                                                                                                                                                                                                         |
| Instances     | 3                                                                                                                                                                                                                                       |

|           |                                                                                                                                                                                     |
|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Solution  | Ensure that Sec-Fetch-Dest header is included in request headers.                                                                                                                   |
| Reference | <a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Dest">https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Dest</a> |
| CWE Id    | <a href="#">352</a>                                                                                                                                                                 |
| WASC Id   | 9                                                                                                                                                                                   |
| Plugin Id | <a href="#">90005</a>                                                                                                                                                               |

|                      |                                         |
|----------------------|-----------------------------------------|
| <b>Informational</b> | <b>Sec-Fetch-Mode Header is Missing</b> |
|----------------------|-----------------------------------------|

|             |                                                                                                                                                                                                                                       |
|-------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description | Allows to differentiate between requests for navigating between HTML pages and requests for loading resources like images, audio etc.                                                                                                 |
| URL         | <a href="http://localhost:3000">http://localhost:3000</a>                                                                                                                                                                             |
| Node Name   | http://localhost:3000                                                                                                                                                                                                                 |
| Method      | GET                                                                                                                                                                                                                                   |
| Parameter   | Sec-Fetch-Mode                                                                                                                                                                                                                        |
| Attack      |                                                                                                                                                                                                                                       |
| Evidence    |                                                                                                                                                                                                                                       |
| Other Info  |                                                                                                                                                                                                                                       |
| URL         | <a href="http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._js">http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._js</a> |
| Node Name   | http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._js                                                                                                                               |
| Method      | GET                                                                                                                                                                                                                                   |
| Parameter   | Sec-Fetch-Mode                                                                                                                                                                                                                        |
| Attack      |                                                                                                                                                                                                                                       |
| Evidence    |                                                                                                                                                                                                                                       |
| Other Info  |                                                                                                                                                                                                                                       |
| URL         | <a href="http://localhost:3000/icon.svg">http://localhost:3000/icon.svg</a>                                                                                                                                                           |
| Node Name   | http://localhost:3000/icon.svg                                                                                                                                                                                                        |
| Method      | GET                                                                                                                                                                                                                                   |
| Parameter   | Sec-Fetch-Mode                                                                                                                                                                                                                        |
| Attack      |                                                                                                                                                                                                                                       |
| Evidence    |                                                                                                                                                                                                                                       |
| Other Info  |                                                                                                                                                                                                                                       |
| Instances   | 3                                                                                                                                                                                                                                     |
| Solution    | Ensure that Sec-Fetch-Mode header is included in request headers.                                                                                                                                                                     |
| Reference   | <a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Mode">https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Mode</a>                                                   |
| CWE Id      | <a href="#">352</a>                                                                                                                                                                                                                   |
| WASC Id     | 9                                                                                                                                                                                                                                     |
| Plugin Id   | <a href="#">90005</a>                                                                                                                                                                                                                 |

|                      |                                         |
|----------------------|-----------------------------------------|
| <b>Informational</b> | <b>Sec-Fetch-Site Header is Missing</b> |
|----------------------|-----------------------------------------|

|             |                                                                                    |
|-------------|------------------------------------------------------------------------------------|
| Description | Specifies the relationship between request initiator's origin and target's origin. |
|-------------|------------------------------------------------------------------------------------|

|            |                                                                                                                                                                                                                                         |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| URL        | <a href="http://localhost:3000">http://localhost:3000</a>                                                                                                                                                                               |
| Node Name  | http://localhost:3000                                                                                                                                                                                                                   |
| Method     | GET                                                                                                                                                                                                                                     |
| Parameter  | Sec-Fetch-Site                                                                                                                                                                                                                          |
| Attack     |                                                                                                                                                                                                                                         |
| Evidence   |                                                                                                                                                                                                                                         |
| Other Info |                                                                                                                                                                                                                                         |
| URL        | <a href="http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js">http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js</a> |
| Node Name  | http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._.js                                                                                                                                |
| Method     | GET                                                                                                                                                                                                                                     |
| Parameter  | Sec-Fetch-Site                                                                                                                                                                                                                          |
| Attack     |                                                                                                                                                                                                                                         |
| Evidence   |                                                                                                                                                                                                                                         |
| Other Info |                                                                                                                                                                                                                                         |
| URL        | <a href="http://localhost:3000/icon.svg">http://localhost:3000/icon.svg</a>                                                                                                                                                             |
| Node Name  | http://localhost:3000/icon.svg                                                                                                                                                                                                          |
| Method     | GET                                                                                                                                                                                                                                     |
| Parameter  | Sec-Fetch-Site                                                                                                                                                                                                                          |
| Attack     |                                                                                                                                                                                                                                         |
| Evidence   |                                                                                                                                                                                                                                         |
| Other Info |                                                                                                                                                                                                                                         |
| Instances  | 3                                                                                                                                                                                                                                       |
| Solution   | Ensure that Sec-Fetch-Site header is included in request headers.                                                                                                                                                                       |
| Reference  | <a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Site">https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Site</a>                                                     |
| CWE Id     | <a href="#">352</a>                                                                                                                                                                                                                     |
| WASC Id    | 9                                                                                                                                                                                                                                       |
| Plugin Id  | <a href="#">90005</a>                                                                                                                                                                                                                   |

|                      |                                                            |
|----------------------|------------------------------------------------------------|
| <b>Informational</b> | <b>Sec-Fetch-User Header is Missing</b>                    |
| Description          | Specifies if a navigation request was initiated by a user. |
| URL                  | <a href="http://localhost:3000">http://localhost:3000</a>  |
| Node Name            | http://localhost:3000                                      |
| Method               | GET                                                        |
| Parameter            | Sec-Fetch-User                                             |
| Attack               |                                                            |
| Evidence             |                                                            |

|            |                                                                                                                                                                                                                                         |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Other Info |                                                                                                                                                                                                                                         |
| URL        | <a href="http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js">http://localhost:3000/_next/static/chunks/%5Bturbopack%5D_browser_dev_hmr-client_hmr-client_ts_57d40746._.js</a> |
| Node Name  | http://localhost:3000/_next/static/chunks/[turbopack]_browser_dev_hmr-client_hmr-client_ts_57d40746._.js                                                                                                                                |
| Method     | GET                                                                                                                                                                                                                                     |
| Parameter  | Sec-Fetch-User                                                                                                                                                                                                                          |
| Attack     |                                                                                                                                                                                                                                         |
| Evidence   |                                                                                                                                                                                                                                         |
| Other Info |                                                                                                                                                                                                                                         |
| URL        | <a href="http://localhost:3000/icon.svg">http://localhost:3000/icon.svg</a>                                                                                                                                                             |
| Node Name  | http://localhost:3000/icon.svg                                                                                                                                                                                                          |
| Method     | GET                                                                                                                                                                                                                                     |
| Parameter  | Sec-Fetch-User                                                                                                                                                                                                                          |
| Attack     |                                                                                                                                                                                                                                         |
| Evidence   |                                                                                                                                                                                                                                         |
| Other Info |                                                                                                                                                                                                                                         |
| Instances  | 3                                                                                                                                                                                                                                       |
| Solution   | Ensure that Sec-Fetch-User header is included in user initiated requests.                                                                                                                                                               |
| Reference  | <a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-User">https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-User</a>                                                     |
| CWE Id     | <a href="#">352</a>                                                                                                                                                                                                                     |
| WASC Id    | 9                                                                                                                                                                                                                                       |
| Plugin Id  | <a href="#">90005</a>                                                                                                                                                                                                                   |

| Informational | Session Management Response Identified                                                                                                                                                                                                                                                                                                                                            |
|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified. |
| URL           | <a href="http://localhost:3000/api/v1/auth/mock-sso/login">http://localhost:3000/api/v1/auth/mock-sso/login</a>                                                                                                                                                                                                                                                                   |
| Node Name     | http://localhost:3000/api/v1/auth/mock-sso/login ()({nycu_id})                                                                                                                                                                                                                                                                                                                    |
| Method        | POST                                                                                                                                                                                                                                                                                                                                                                              |
| Parameter     | data.access_token                                                                                                                                                                                                                                                                                                                                                                 |
| Attack        |                                                                                                                                                                                                                                                                                                                                                                                   |
| Evidence      | data.access_token                                                                                                                                                                                                                                                                                                                                                                 |
| Other Info    | json:data.access_token                                                                                                                                                                                                                                                                                                                                                            |
| Instances     | 1                                                                                                                                                                                                                                                                                                                                                                                 |
| Solution      | This is an informational alert rather than a vulnerability and so there is nothing to fix.                                                                                                                                                                                                                                                                                        |
| Reference     | <a href="https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/">https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/</a>                                                                                                                                                                                               |
| CWE Id        |                                                                                                                                                                                                                                                                                                                                                                                   |
| WASC Id       |                                                                                                                                                                                                                                                                                                                                                                                   |

|                      |                                                                                                                                                                                                                                                                                                                                                         |
|----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Plugin Id            | <a href="#">10112</a>                                                                                                                                                                                                                                                                                                                                   |
| <b>Informational</b> | <b>Storable but Non-Cacheable Content</b>                                                                                                                                                                                                                                                                                                               |
| Description          | The response contents are storable by caching components such as proxy servers, but will not be retrieved directly from the cache, without validating the request upstream, in response to similar requests from other users.                                                                                                                           |
| URL                  | <a href="http://localhost:3000/icon.svg">http://localhost:3000/icon.svg</a>                                                                                                                                                                                                                                                                             |
| Node Name            | http://localhost:3000/icon.svg                                                                                                                                                                                                                                                                                                                          |
| Method               | GET                                                                                                                                                                                                                                                                                                                                                     |
| Parameter            |                                                                                                                                                                                                                                                                                                                                                         |
| Attack               |                                                                                                                                                                                                                                                                                                                                                         |
| Evidence             | max-age=0                                                                                                                                                                                                                                                                                                                                               |
| Other Info           |                                                                                                                                                                                                                                                                                                                                                         |
| URL                  | <a href="http://localhost:3000/nycu-favicon.svg">http://localhost:3000/nycu-favicon.svg</a>                                                                                                                                                                                                                                                             |
| Node Name            | http://localhost:3000/nycu-favicon.svg                                                                                                                                                                                                                                                                                                                  |
| Method               | GET                                                                                                                                                                                                                                                                                                                                                     |
| Parameter            |                                                                                                                                                                                                                                                                                                                                                         |
| Attack               |                                                                                                                                                                                                                                                                                                                                                         |
| Evidence             | max-age=0                                                                                                                                                                                                                                                                                                                                               |
| Other Info           |                                                                                                                                                                                                                                                                                                                                                         |
| Instances            | 2                                                                                                                                                                                                                                                                                                                                                       |
| Solution             |                                                                                                                                                                                                                                                                                                                                                         |
| Reference            | <a href="https://datatracker.ietf.org/doc/html/rfc7234">https://datatracker.ietf.org/doc/html/rfc7234</a><br><a href="https://datatracker.ietf.org/doc/html/rfc7231">https://datatracker.ietf.org/doc/html/rfc7231</a><br><a href="https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html">https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html</a> |
| CWE Id               | <a href="#">524</a>                                                                                                                                                                                                                                                                                                                                     |
| WASC Id              | 13                                                                                                                                                                                                                                                                                                                                                      |
| Plugin Id            | <a href="#">10049</a>                                                                                                                                                                                                                                                                                                                                   |

## Sequence Details

With the associated active scan results.